

Continuous Policy Governance, Explained.

A product walkthrough — real screens, real findings, from the running platform.

SOCIÉTÉ GÉNÉRALE CHALLENGE · IEEE-830 SRS BASELINE · DETERMINISTIC AI ENGINE

THE PROBLEM

Enterprises accumulate dozens of security & compliance policies written by different teams over many years, so contradictions ("rotate passwords every 90 days" vs "never rotate — enforce MFA"), silent redundancy, and stale references to dead tech (TLS 1.0, SHA-1, Server 2012) pile up unnoticed. Today those gaps are found **by auditors, not before them** — creating real audit, legal, and breach exposure.

THE SOLUTION

Sentinal continuously ingests policies (GitHub, folders, upload), extracts every obligation, and runs a deterministic AI engine that flags conflicts, redundancy, and staleness — each finding cites the **exact triggering text** and a suggested resolution. A live operations console ranks findings by severity × confidence, maps them to **ISO 27001 / NIST / GDPR / COBIT**, and collapses 20+ hrs/quarter of manual reconciliation into a ranked, audit-ready list.

SUCCESS METRICS & ACCEPTANCE (SRS §6)

METRIC	TARGET	ACCEPTANCE TEST
Conflict detection rate	> 75%	tests/ai/test_conflicts.py
Redundancy detection	> 70%	tests/ai/test_redundancy.py
Staleness detection	> 90%	tests/ai/test_staleness.py
False-positive rate	< 20%	tests/ai/test_precision.py
Obligation-extraction accuracy	> 80%	tests/ai/test_obligations.py
End-to-end run	passes	POST /api/v1/analysis/run

LIVE DEMO

sentinal-taupe.vercel.app

SOURCE REPO

github.com/rithvin-us/Policy-Conflict-and-Staleness-Detector

LIVE API + OPENAPI

policy-guardian-backend-wbge.onrender.com/docs

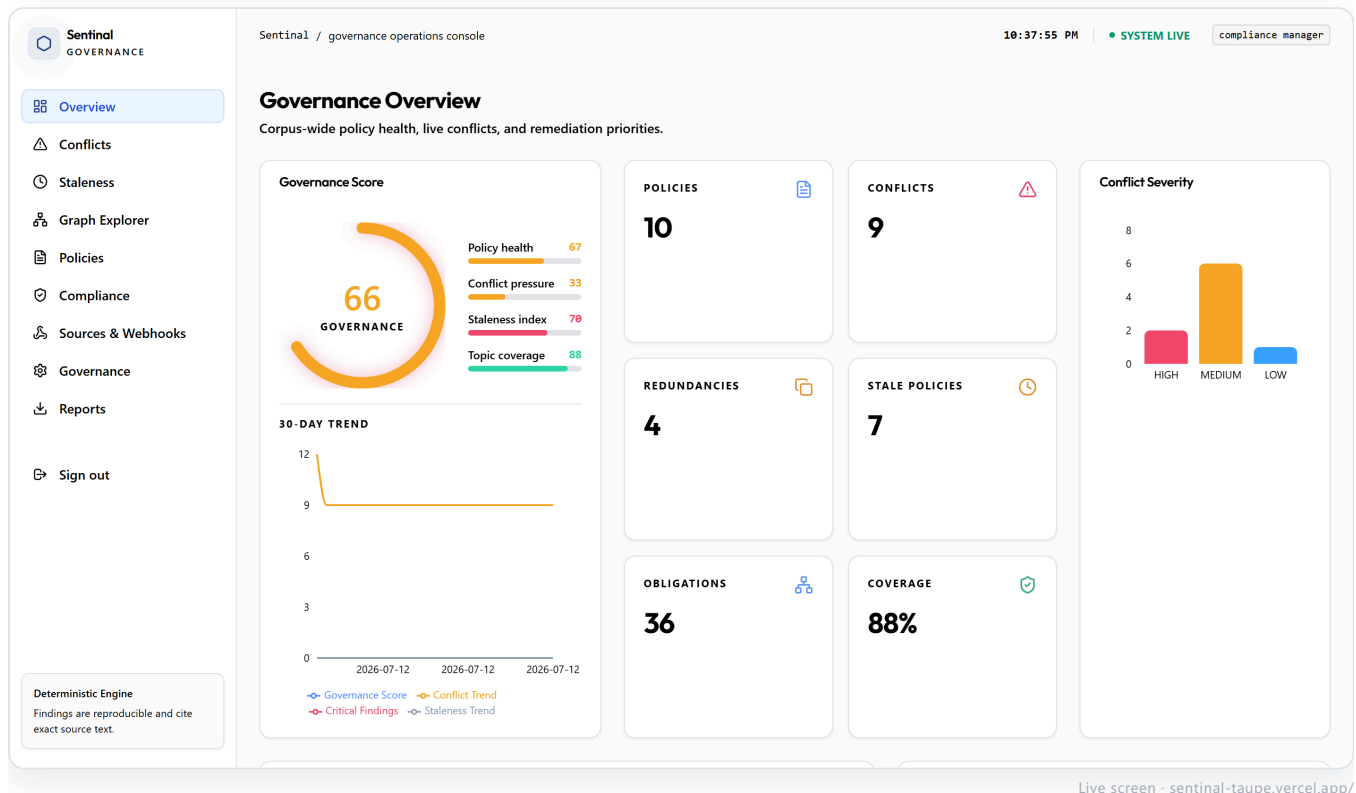
DEMO VIDEO / DECK

► [paste hosted URL](#)

SECTION 01

Governance Overview

Single pane of glass — corpus-wide health, live findings, and remediation pressure.



The landing console computes a composite **Governance Score (66/100)** from six weighted inputs — policy health, conflict pressure, staleness index, and topic coverage among them — over a real corpus of **10 policies**. Every tile is populated from the live API, not mocked: **9 active conflicts**, **4 redundancies**, **7 stale policies**, **36 extracted obligations**, and **88% topic coverage**.

WHAT THIS PROVES

- **Governance Score** is deterministic: same corpus → same score, every run (NFR-2).
- **Conflict Severity** chart breaks the 9 findings into HIGH / MEDIUM / LOW so a manager triages by risk, not volume.
- **30-day trend** tracks whether governance debt is rising or being paid down.

SECTION 02

Conflicts & Redundancies

Every finding cites the exact triggering text and a resolution — click any row to compare side by side.

Sentinal
GOVERNANCE

Overview

Conflicts

Staleness

Graph Explorer

Policies

Compliance

Sources & Webhooks

Governance

Reports

Sign out

Deterministic Engine

Findings are reproducible and cite exact source text.

Sentinal / governance operations console

10:38:02 PM | SYSTEM LIVE | compliance manager

Conflicts & Redundancies

Every finding cites the exact triggering text and a resolution. Click a row to compare side by side.

All Severity

All Type

SEVERITY	TYPE	POLICIES	EXPLANATION	CONF.	RISK
HIGH	DIRECT	POL-PRV-004 ↔ POL-RET-003	One policy mandates 'retain' while the other mandates the opposite for ...	88%	79
HIGH	DIRECT	POL-CLD-002 ↔ POL-PWD-001	One policy mandates 'rotate' while the other mandates the opposite for ...	88%	76
MEDIUM	TEMPORAL	POL-BAK-010 ↔ POL-PRV-004	Data_Retention obligations point in opposite directions for different sco...	68%	28
MEDIUM	TEMPORAL	POL-PRV-004 ↔ POL-RET-003	Data_Retention obligations point in opposite directions for different sco...	68%	28
MEDIUM	SCOPE	POL-PRV-004 ↔ POL-RET-003	Data_Retention obligations point in opposite directions for different sco...	68%	24
MEDIUM	SCOPE	POL-PRV-004 ↔ POL-RET-003	Data_Retention obligations point in opposite directions for different sco...	68%	24
MEDIUM	SCOPE	POL-BAK-010 ↔ POL-PRV-004	Data_Retention obligations point in opposite directions for different sco...	68%	24
MEDIUM	PARAMETER	POL-BAK-010 ↔ POL-RET-003	Both policies require 'retain' on data_retention but with different parame...	60%	18
LOW	SCOPE	POL-DEV-006 ↔ POL-NET-005	Network obligations differ, but the narrower scope 'developers' is a per...	70%	9
LOW	REDUNDANCY	POL-CLD-002 ↔ POL-ENC-008	Both policies state the same 'encrypt' obligation on encryption (similarit...	90%	7
LOW	REDUNDANCY	POL-ENC-008 ↔ POL-NET-005	Both policies state the same 'encrypt' obligation on encryption (similarit...	73%	6
LOW	REDUNDANCY	POL-CLD-002 ↔ POL-NET-005	Both policies state the same 'encrypt' obligation on encryption (similarit...	73%	6

Live screen · sentinal-taupe.vercel.app/conflicts

This is the core intelligence. The engine reasons across obligations on the same topic and classifies each finding into one of five conflict types — **DIRECT, TEMPORAL, SCOPE, STRENGTH, PARAMETER** — plus redundancy. Example: **POL-CLD-002 ↔ POL-PWD-001**, a **HIGH / DIRECT** conflict at **88% confidence** — one policy mandates 'rotate' while the other mandates the opposite, despite sharing almost no keywords.

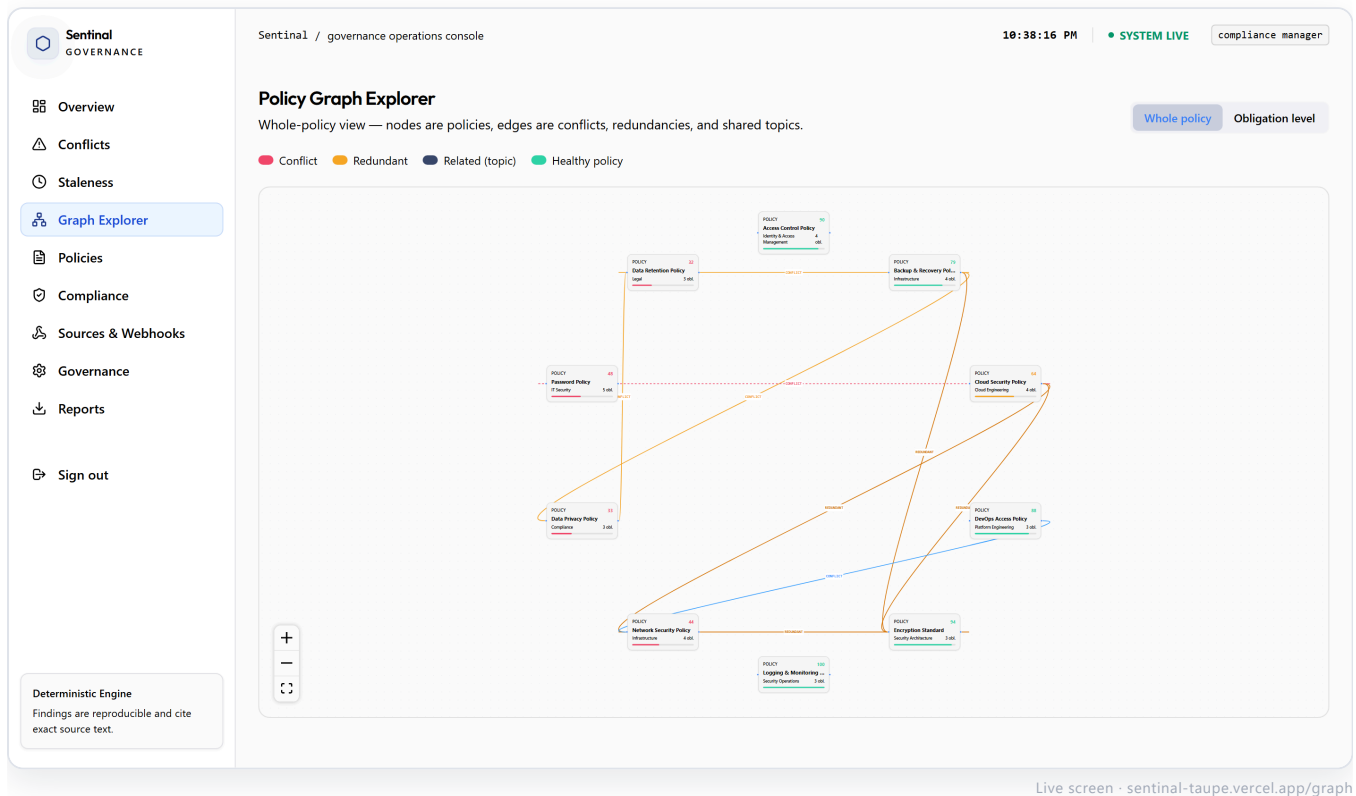
WHAT THIS PROVES

- Each row carries **severity, type, the policy pair, a plain-English explanation, confidence %, and a risk score** — sorted by severity × risk.
- Precision-first**: a scope exception downgrades a finding to LOW rather than crying wolf (FPR target < 20%).
- This is meaning-level reasoning, **not grep** — it catches contradictions with zero shared vocabulary.

SECTION 03

Policy Graph Explorer

Whole-policy view — nodes are policies, edges are conflicts, redundancies, and shared topics.



The knowledge graph turns the findings list into a map of where governance debt clusters. Nodes are policies (each badged with its health score); edges are colour-coded — **red = conflict**, **amber = redundant**, **blue/grey = related topic**. A toggle switches between the whole-policy view and a finer **obligation-level** graph.

WHAT THIS PROVES

- Rendered from React-Flow-ready JSON served straight off the API (FR-8).
- Instantly surfaces the most entangled policies — e.g. **Data Retention** and **Backup & Recovery** pulling in opposite directions.
- Gives auditors a visual, not just tabular, argument for why a policy needs attention.

SECTION 04

Staleness Surveillance

Review-overdue policies, deprecated-tech references, superseded standards, and orphaned owners.

Sentinal
GOVERNANCE

Overview

Conflicts

Staleness

Graph Explorer

Policies

Compliance

Sources & Webhooks

Governance

Reports

Sign out

Deterministic Engine
Findings are reproducible and cite exact source text.

Sentinal / governance operations console

10:38:09 PM | SYSTEM LIVE | compliance manager

Staleness Surveillance

Review-overdue policies, deprecated technology references, superseded standards, and orphaned owners.

HIGH

REVIEW OVERDUE

POL-NET-005

64mo

Last reviewed 2021-03-30 (64 months ago)

→ Schedule an immediate review; policy exceeds the 18-month review cadence (ISO 27001 A.5.2).

100
RISK

HIGH

REVIEW OVERDUE

POL-PMD-001

59mo

Last reviewed 2021-08-15 (59 months ago)

→ Schedule an immediate review; policy exceeds the 18-month review cadence (ISO 27001 A.5.2).

100
RISK

HIGH

DEPRECATED TECH

POL-NET-005

64mo

TLS 1.0 is deprecated (RFC 8996); require TLS 1.2+.; Windows Server 2012 is end-of-life (Oct 2023).

→ Remove references to deprecated technology and align with current cryptographic and platform baselines.

100
RISK

HIGH

REVIEW OVERDUE

POL-RET-003

38mo

Last reviewed 2023-05-10 (38 months ago)

→ Schedule an immediate review; policy exceeds the 18-month review cadence (ISO 27001 A.5.2).

100
RISK

Live screen · sentinal-taupe.vercel.app/staleness

Staleness is tracked as four distinct signals. The console flags policies past the **18-month review cadence (ISO 27001 A.5.2)** with exact months overdue, and detects **deprecated technology** in the text — here **TLS 1.0 (RFC 8996)** and **Windows Server 2012 (end-of-life Oct 2023)** — each with a concrete remediation and a risk score.

WHAT THIS PROVES

- POL-NET-005** last reviewed 64 months ago → RISK 100, 'schedule immediate review'.
- Deprecated-tech detection reads the actual policy body, not just metadata.
- Every finding names the **source, the standard, and the fix** — audit-ready by construction.

SECTION 05

Compliance Mapping

Framework coverage across ISO 27001, NIST SP 800-53, GDPR, and COBIT 2019 — audit evidence at a glance.

The screenshot shows the Sentinel Governance Console interface. On the left is a sidebar with navigation links: Overview, Conflicts, Staleness, Graph Explorer, Policies, Compliance (highlighted), Sources & Webhooks, Governance, Reports, and Sign out. The main content area is titled 'Compliance Mapping' and shows framework coverage across ISO 27001, NIST SP 800-53, GDPR, and COBIT 2019. The top right shows the time 10:38:31 PM, system status 'SYSTEM LIVE', and the user 'compliance manager'. There are buttons for 'Auto-Sync' and '+ Add Framework'. The main content is divided into two sections: ISO 27001 and NIST SP 800-53. Each section lists specific control clauses with their status (green checkmark for compliant, red exclamation mark for non-compliant) and the number of policies covering them. For ISO 27001, the clauses are A.5.1 (3 policies, 1 finding), A.5.2 (0 policies), A.5.15 (3 policies), and A.8.24 (6 policies, 4 findings). For NIST SP 800-53, the clauses are PL-1 (0 policies), PM-1 (0 policies), and IA-5 (2 policies, 1 finding). On the right, the 'Coverage Gaps & Risks' panel shows three topics: DATA_CLASSIFICATION, BACKUP, and INCIDENT_RESPONSE, each with a 'VIEW RISK DETAILS' button. A 'Deterministic Engine' note at the bottom left states: 'Findings are reproducible and cite exact source text.'

Live screen · sentinel-taupe.vercel.app/compliance

Every obligation is mapped to specific control clauses — **ISO 27001** (A.5.1, A.5.2, A.5.15, A.8.24), **NIST 800-53** (PL-1, PM-1, IA-5), GDPR, and COBIT. The **Coverage Gaps & Risks** panel is the audit killer feature: it flags topics with **zero governing obligations** — DATA_CLASSIFICATION, BACKUP, INCIDENT_RESPONSE — before an auditor does.

WHAT THIS PROVES

- Per-clause view shows how many policies cover it and how many findings it carries.
- **A.5.2 'Review of the policies' → 0 policies**: a coverage gap made visible.
- Turns 'these two policies conflict' into '...and here's the control they both touch'.

SECTION 06

Policy Library & Versioning

10 policies under continuous governance, sorted by health — with owner, version, and review date.

Sentinal
GOVERNANCE

Overview

Conflicts

Staleness

Graph Explorer

Policies

Compliance

Sources & Webhooks

Governance

Reports

Sign out

Deterministic Engine
Findings are reproducible and cite exact source text.

Sentinal / governance operations console10:38:24 PM • SYSTEM LIVEcompliance manager

Policy Library
10 policies under continuous governance. Sorted by health.

Upload Policy

Search policies...

All Health Scores

All Dates

POLICY	OWNER	VERSION	REVIEWED	OBL.	HEALTH
Data Retention Policy POL-RET-003	Legal	v1.3	2023-05-10	3	32
Data Privacy Policy POL-PRIV-004	Compliance	v2.0	2024-02-28	3	33
Network Security Policy POL-NET-005	Infrastructure	v1.1	2021-03-30	4	44
Password Policy POL-PWD-001	IT Security	v2.1	2021-08-15	5	48
Cloud Security Policy POL-CLD-002	Cloud Engineering	v1.0	2024-11-20	4	64
Backup & Recovery Policy POL-BAK-010	Infrastructure	v1.0	2025-05-30	4	79
DevOps Access Policy POL-DEV-006	Platform Engineering	v1.0	2024-08-12	3	88
Access Control Policy POL-ACC-007	Identity & Access Management	v1.2	2025-01-20	4	90

Live screen · sentinel-taupe.vercel.app/policies

The inventory is the source of truth. Each policy shows its **owner**, **version (v1.3, v2.1, ...)**, **last-reviewed date**, **obligation count**, and a **health bar**. Re-ingesting a changed policy creates a new version and preserves history, so the corpus is governed continuously rather than scanned once.

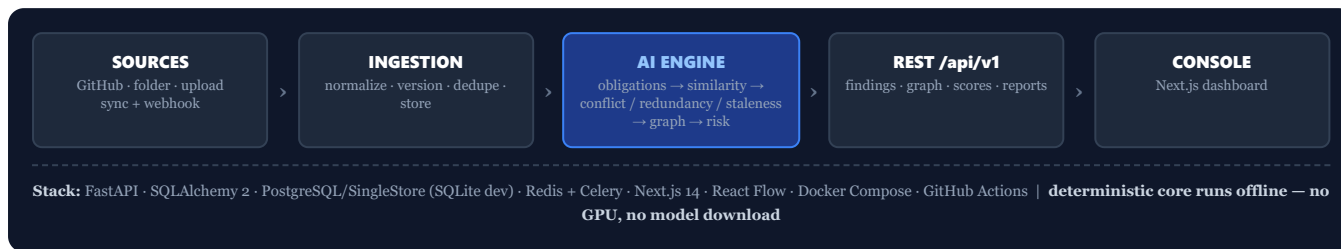
WHAT THIS PROVES

- Health scoring is per-policy: **Data Retention 32** (red) vs **Access Control 90** (green).
- Ingested from GitHub, local folders, or direct upload via a pluggable connector framework.
- Content-hash dedupe means no-op syncs don't create noise (FR-1 / FR-2).

SECTION 07

How It Works & What Judges Ask

The pipeline behind every screen, plus the five questions judges always ask — answered straight.



▸ What is actually "AI" vs. plain rules?

A deterministic NLP engine: modal→strength, verb→action, negation→polarity, topic/scope maps, then cross-obligation reasoning over 5 conflict classes. An optional embedding layer only *adds* candidate pairs — it never overturns a deterministic finding. Precision + reproducibility by design.

▸ How is it different from a linter or grep?

grep matches strings; Sentinel reasons over meaning — it flags "rotate every 90 days" vs "never rotate" as a conflict with zero shared keywords, weighs scope exceptions, and maps each hit to a compliance clause.

▸ Does it scale beyond the seed data?

Connectors ingest arbitrary repos/folders; ingestion versions + dedupes by content hash; webhooks re-analyze only what changed. Target: 30-policy corpus in < 10 s on the deterministic path.

▸ What is real vs. stubbed?

Real & runnable: ingestion, obligation extraction, all 5 conflict detectors, redundancy, staleness, risk/governance scoring, knowledge graph, explainable findings, MD/HTML/JSON reports, GitHub + Local + Upload connectors, webhook-in, compliance mapping, Docker + CI + tests. **Stubs (same interface):** GitLab, Bitbucket, Drive, OneDrive, SharePoint, Slack, Teams. **Roadmap:** PDF/DOCX ingest, version-diff, NL query, RBAC/SSO.

▸ What's the business case?

Compliance teams burn 20+ hours/quarter manually reconciling policies for ISO 27001 \$5.1/\$5.2 audits. Sentinel turns that into reviewing a ranked, evidenced list and exports a Compliance Coverage report as audit evidence — measurable audit-overhead reduction plus lower legal/breach exposure.